AssetTrust v0.62 | Security assessment

11 November 2026 • Operational-data row-level security • Release decision: NO-GO

Security scope	Offline evidence	Release status
13 RLS tables in source	18 / 18 new tests	NO-GO
12 new tenant-matched FKs	60 / 60 version suites	3 / 11 preflight
27 migration hashes	Static CI, architecture, syntax	Live tests unrun

Implemented security controls

- Forced PostgreSQL RLS for tasks, disputes, monitoring reminders and verification quotes, restricted to the transaction-local organization.
- Recipient-private notifications: SELECT and UPDATE require both the organization and authenticated actor; INSERT requires a matching organization; no DELETE policy.
- Twelve organization-matched composite foreign keys prevent operational rows from referencing a case, asset, user or recipient in another organization.
- Notification reads and mark-read actions now execute within PostgreSQL transactions that set tenant and actor identity locally.
- Production startup and restricted-role validation now cover 13 RLS tables. Three older live runners were fixed to use the complete protected-table inventory.

Verification achieved in the checkpoint environment

Offline: 18 new security tests passed; all 60 historical/current version suites passed; 27 SQL migration hashes match. CI workflow structure, architecture, TypeScript syntax and static source checks passed. The source snapshot scan found no high-confidence credential matches in 2,858 inspected files.

Not executed live: PostgreSQL migration 027, the two-organization and sibling-recipient contract, ClamAV, authenticated HTTP/browser workflows, full Git history review, infrastructure security and recovery drills.

Failures and release blockers

- npm ci fails because there is no genuine package-lock.json; installing dependencies from the npm registry is unavailable in this environment.
- The full API/React build is not verified. The API build fails on missing installed TypeScript/Node and NestJS dependencies.
- Release preflight reports 3 of 11 prerequisites present. Passing source-only tests is not equivalent to production readiness.

Migration and rollout restrictions

Migration 027 must not be applied while an older API is still serving notifications. Before any deployment, restore-test a database backup, run the 12 read-only historical relationship probes, confirm there are no mismatches, apply the migration in isolated staging, and validate both authorized and cross-tenant operations with a separate non-bypass runtime login. The migration deliberately fails instead of deleting inconsistent records.

Residual risk and release decision

Other sensitive tables remain outside this staged RLS rollout. Transaction-local tenant/actor settings do not replace permission checks or protection against SQL injection and privileged database access. The application is not an official government land-title certification system.

Decision: NO-GO. Do not deploy with real customer records or commercial transactions before genuine reproducible builds, full live database/security tests and independent release approval.

Supporting records: V62_SECURITY_REPORT.md, V62_KALI_VALIDATION.md, TEST_EVIDENCE_V62.md and V62_HANDOVER.md.